



**POLYTECHNIQUE
MONTRÉAL**

UNIVERSITÉ
D'INGÉNIERIE

INF8108 : Gestion et chasse de la cybermenace

Travaux pratiques 01 : Attaque et défense par/contre hameçonnage

Table des matières

Table des matières	2
1 Campagnes d'hameçonnage par SMS [/10pts]	5
1.1 Défense - Investigation de campagnes d'hameçonnage [/7pts]	5
1.2 Attaque - Mise en oeuvre de campagnes d'hameçonnage [/3pts]	6
2 Campagnes d'hameçonnage par clé USB piégée [/10pts]	7
2.1 Défense - Investigation de campagnes d'hameçonnage [/7pts]	7
2.2 Attaque - Mise en oeuvre de campagnes d'hameçonnage [/3pts]	7
3 Campagnes d'hameçonnage par courriel [/10pts]	8
3.1 Défense - Investigation de campagnes d'hameçonnage [/7pts]	8
3.2 Attaque - Mise en oeuvre de campagnes d'hameçonnage [/3pts]	8
4 Moyens de défense contre les campagnes d'hameçonnage [/20pts]	9
4.1 Moyens de prévention [/6pt]	9
4.2 Moyens de détection [/2pts]	9
4.3 Moyens de réaction [/12pts]	9

Directives

Constitution d'équipes

Le travail devra être fait par équipe. L'étudiant(e) choisit librement ses coéquipier(e)s et en informe le chargé de laboratoires. L'équipe ainsi constituée restera figée pour l'ensemble des laboratoires du cours. Toute exception devra être approuvée au préalable par le chargé de laboratoires.

Remise du travail

La date de remise de rapport est communiquée dans le plan du cours et configurée dans la boîte de remise Moodle du cours. Tous les travaux devront être remis avant 23h55 le jour de la remise sur le site Moodle du cours. À moins que cela ne soit explicitement demandé dans le sujet, vous ne devez remettre qu'un seul fichier PDF nommé selon le format TPX-matricule1-matricule2.pdf. Vous pouvez inclure des annexes dans votre rapport si vous jugez que cela améliore la lisibilité (code source, ...).

Éléments évalués

L'orthographe, la grammaire et la forme seront prises en compte pour chacune des questions. Pour toutes les questions, vous devez expliquer et montrer comment vous avez obtenu les réponses, incluant des captures d'écran montrant les commandes utilisées et leurs sorties. Toutes les sources d'information, qu'elles soient humaines ou documentaires, doivent être citées.

- Toute réponse non justifiée ne rapporte aucun point.
- Tout soupçon de plagiat sera reporté au représentant du directeur des études du cycle.

Introduction

Les attaques par ingénierie sociale émergent comme un problème majeur qui remet en question la notion de correctifs de sécurité [Mike Danseglio, 2004] car elle transcende les barrières technologiques des systèmes de défense même les plus avancés [Kevin Mitnick, 2011]. Plutôt que de s'attaquer aux systèmes informatiques, les hackers malveillants s'attaquent par ingénierie sociale aux personnes utilisant ces systèmes [Bruce Schneier, 2012].

Selon le CRTC ([lien](#)), plus de 6 796 plaintes liées à des attaques d'hameçonnage ont été déposées par semaine du 1er octobre 2022 au 31 mars 2023. Cette augmentation alarmante démontre la nécessité urgente d'approfondir la compréhension de cette menace et de mettre en œuvre des stratégies efficaces pour la contrer.

Ce travail pratique vise à explorer les aspects essentiels de l'hameçonnage, en analysant les techniques employées par les attaquants, en examinant les facteurs qui rendent les utilisateurs vulnérables et en proposant des mesures de défense pour prévenir de telles attaques.

Scénario

La crise géopolitique entre la Russie et l'Ukraine s'intensifie, et le Canada continue de soutenir le peuple et le gouvernement ukrainien dans cette période de troubles. En réponse à ce soutien, des auteur(e)s de cybermenaces dont les intérêts correspondent à ceux de la Russie ont lancé des cyberopérations offensives contre les institutions gouvernementales, les entreprises privées et les institutions académiques du Canada [Gouvernement du Canada, 2023]. (lien)

En tant qu'étudiant(e)s inscrit(e)s dans le parcours « spécialiste cyberdéfense » de Polytechnique Montréal, vous êtes invité(e)s à mener des cyberopérations défensives et, lorsque cela est nécessaire et faisable, des cyberopérations actives [Forces Armées Canadiennes, 2023]. (lien)

Apprenez-vous à faire de la **Threat Intelligence**, **Threat Hunting**, **Investigation** et **Hacking back**.

Le TP se compose de 3 parties :

- 1 : Analyse d'une URL malveillante (Malicious URL Analysis)
- 2 : Criminalistique numérique (Digital Forensics)
- 3 : Analyse d'une pièce-jointe suspecte (Suspicious File Attachment Analysis)

Avertissement

Les compétences acquises dans les travaux pratiques peuvent avoir un potentiel d'utilisation abusive ou illégale. Nous rappelons que toute utilisation de ces compétences doit être réalisée de manière éthique et légale. Ni les auteur(e)s de ce cours ni Polytechnique Montréal ne peuvent être tenu(e)s responsables de l'utilisation non conforme à ces principes. (lien)

Ressources utiles

1. Supports de cours officiels - Gestion et chasse de la cybermenace INF8108 (lien)
2. Formation obligatoire en cybersécurité et cyberdéfense (lien)
3. Phishing Attacks : What You Should Know About Phishing Activities (Part 1), (Part 2)
4. How To Run a Phishing Engagement for Penetration Testers (Part 1), (Part 2), (Part 3)
5. How to Investigate Phishing Campaigns (lien)
6. Intro to Cyber Threat Intel (lien)
7. Threat Intelligence Tools (lien)
8. Phishing Emails (Part 1, Part 2, Part 3, Part 4, Part 5)
9. Threat Intelligence for SOC (lien)
10. Attaques applicatives via périphériques USB modifiés : infection virale et fuites d'infos (lien)
11. Cyber Threat Intelligence knowledge template (lien)

1 Campagnes d'hameçonnage par SMS [/ 10pts]

Vous avez récemment annoncé votre admission en maîtrise « parcours spécialiste cyberdéfense » à Polytechnique Montréal sur vos différents réseaux sociaux notamment Facebook, LinkedIn et X.

La date prévue pour votre début de programme est lundi 28 août 2023.

Ce matin, vous recevez un SMS inattendu qui semble émaner de votre institution financière. Ce message signale la détection d'une activité suspecte liée à l'utilisation de votre carte de crédit et vous demande de cliquer immédiatement sur un lien pour modifier vos informations.

Vous devez analyser la situation et engager une réponse active contre ces auteur(e)s.

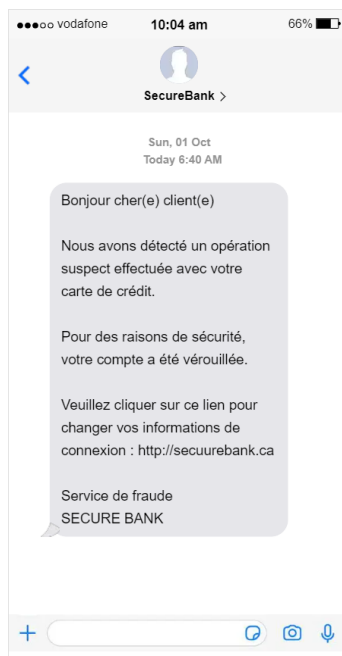


FIGURE 1 – Capture d'écran du SMS reçu

1.1 Défense - Investigation de campagnes d'hameçonnage [/7pts]

- 1.1.1 Expliquer brièvement les principales étapes de la chasse à la cybermenace.
- 1.1.2 Comment un(e) auteur(e) de cybermenaces collecte-il(elle) des numéros de téléphone ?
- 1.1.2 Repérer les signaux d'alerte indiquant que le message reçu est frauduleux et non légitime.
- 1.1.3 Est-il possible de répondre à l'expéditeur ? Justifier votre réponse.
- 1.1.4 Le *Short Code* correspondant au *Sender ID* est 25392. Quel service web a été utilisé ?
- 1.1.5 Est-il possible de répondre à l'expéditeur sous l'hypothèse en 1.1.4 ? Justifier votre réponse.
- 1.1.6 Est-il toujours possible de visiter une page de hameçonnage sur différents types d'appareils (mobile, tablette, ordinateur) ou des services tels que URLscan ? Justifier votre réponse.
- 1.1.7 Les liens suspects sont régulièrement signalés par les utilisateurs. Comment peut-on y accéder lorsqu'ils sont désactivés après un certain nombre de signalements ?
- 1.1.8 L'auteur(e) de la campagne d'hameçonnage a su efficacement empêcher la proposition en 1.1.7 par des moyens techniques spécifiques. De quoi peut-il s'agir ?

1.1.9 Sous l'hypothèse en 1.1.7, vous êtes contraint(e)s de choisir une campagne d'hameçonnage actuellement active pour répondre aux questions suivantes.

- Recherche de scans récents des utilisateurs de URLscan : (URLscan)
- Recherche de scans récents des utilisateurs de Phistank : (Phistank)
- Liste des noms de domaines (TLDs) français récemment enregistrés : (RedFlag)
- Recherche par mots-clés sur Twitter : "smishing scams" ou "scam text" : (Twitter)

1.1.10 a) Vérifier la réputation et le comportement de la page avec des environnement isolés comme Browserling, URLscan, VirusTotal, Hybrid Analysis, ou Any.run.

1.1.10 b) Utiliser le proxy Burp Suite pour intercepter et analyser le trafic HTTP(S) échangé avec le serveur malicieux. Que se passe-t-il lorsque des données erronées puis valides sont saisies ?

1.1.10 c) Utiliser Whois DomainTools pour recueillir des informations sur le domaine, notamment sa date de création, son titulaire d'enregistrement, et l'emplacement de son hébergement.

1.1.10 d) Est-il possible d'obtenir la vraie IP liée à ce domaine ? Justifier votre réponse. (lien)

1.1.10 e) Exploiter les caractéristiques de la page d'hameçonnage tels que les répertoires, les chemins de fichier ou encore les favicons pour identifier d'autres campagnes similaires. Conclure.

1.1.10 f) Consulter les enregistrements SPF, DKIM, DMARC et MX du domaine à l'aide d'outils tels que Mxtoolbox. Peut-on usurper ce domaine ?

1.1.10 g) Le nom de domaine polymtl.ca a-t-il été utilisé dans une campagne d'hameçonnage ?

1.1.10 h) Quels indicateurs de compromission pertinents issus de cette campagne faut-il partager avec la communauté cyber ?

1.1.10 i) Modéliser la chaîne de frappe (Kill chain) de cette campagne d'hameçonnage.

1.2 Attaque - Mise en oeuvre de campagnes d'hameçonnage [/3pts]

Elaborer et exécuter une attaque d'hameçonnage par SMS ciblant l'utilisateur +1 438 808 4038. Collecter le maximum d'informations incluant son nom d'utilisateur, son mot de passe, son IP, le nom de son opérateur téléphonique, le nom de sa banque, etc.

L'attaque doit être la plus réaliste, furtive et originale possible ! Noter les matricules en fin du SMS.

Voici quelques outils qui pourront être utiles :

- Générateur de nom de domaine : DNStwist, Spooftpoint, ...
- Traqueur d'URL : Grabify, IPlogger ou script personnalisé
- Réducteur d'URL : TINURL, CUTTLY, ...
- Ligne mobile virtuelle (eSIM) : ON/OFF, Textnow, ...
- API de SMS pour usurpation d'SMS : Octopush, Twilio, AWS SNS, ...
- Générateur de faux SMS en image : Fake Message Generator

2 Campagnes d'hameçonnage par clé USB piégée [/10pts]

Les mêmes auteur(e)s de cybermenaces ont pris part aux activités d'accueil organisées par Go-Poly, où ils(elles) ont distribué gratuitement des clés USB aux nouveaux(elles) arrivant(e)s.

Après avoir reçu l'une de ces clés, vous commencez à remettre en question cette apparente générosité, en particulier à la lumière de l'analyse que vous avez effectuée dans la section 1.

Il vous incombe de persuader le service des technologies de l'information de l'importance de diffuser un message d'alerte à l'ensemble de la communauté de Polytechnique Montréal.

NOTE : N'ouvrez pas le fichier **polymtl-usb.zip** dans votre environnement local !!! Optez plutôt pour une machine virtuelle ou un environnement isolé (sandbox) car il contient un fichier malveillant.

2.1 Défense - Investigation de campagnes d'hameçonnage [/7pts]

2.1.1 Quel fichier est exécuté par le fichier de configuration "autorun.inf" ? (lien1), (lien2)

2.1.2 Ce fichier est-il légitime ou suspect ? ?

2.1.3 Ce fichier a-t-il le bon "magic number" ? (lien 1), (lien 2)

2.1.4 Quel type de système d'exploitation ce fichier peut-il exploiter ?

2.1.5 Un exécutable Windows est mentionné dans ce fichier, de quoi s'agit-il ?

2.1.6 Combien d'éléments suspects ce fichier contient-il ?

2.2 Attaque - Mise en oeuvre de campagnes d'hameçonnage [/3pts]

Elaborer une attaque par port USB que les auteur(e)s de cybermenace pourraient avoir utilisée.

La charge utile consistera en un simple keylogger capable d'envoyer les identifiants du réseau WiFi auquel la machine est connectée ainsi que les identifiants stockés dans le navigateur de l'utilisateur, vers un serveur C2.

NB : Fournir un code prêt à l'emploi ("How-To" directement dans le code source).

Quelques ressources qui pourraient vous servir :

- Implementation of BadUSB written in Python : PyBadUSB
- PythonKeylogger : BadUSB + ChromeVirus : PythonKeylogger
- How to Make a Malicious USB Device and Have Some Harmless Fun : Malicious USB
- Convert DuckyScript scripts to Python programs : ducky2python

3 Campagnes d'hameçonnage par courriel [/10pts]

A la suite de l'alerte générale lancée en 2, le service de traitement des incidents de sécurité à Polytechnique Montréal est submergé par l'analyse des nombreux courriels d'hameçonnage qui sont transférés à polyspam@polymtl.ca conformément aux instructions disponibles ici.

Un ticket de priorité moins élevée vous a été assigné. Vous devez analyser le courriel **polymtl.eml** et prendre des mesures actives en réponse à cette menace (hackback).

NOTE : N'ouvrez pas le fichier **polymtl-mail.zip** dans votre environnement local!!! Optez plutôt pour une machine virtuelle ou un environnement isolé (sandbox) car il contient un fichier malveillant.

3.1 Défense - Investigation de campagnes d'hameçonnage [/7pts]

- 3.1.1 Comment un(e) auteur(e) de cybermenaces collecte-il(elle) des adresses courriels ?
- 3.1.2 Utiliser l'une des techniques proposées en 3.1.1 pour collecter au moins 50 adresses courriels valides de la communauté de Polytechnique Montréal. Expliquer la démarche et les hypothèses.
- 3.1.4 Vos adresses courriels sont-elles répertoriées dans des violations de données (dataleaks) ? Vérifier sur les services tels que Hunter.io, Haveibeenpwned, DeHashed, LeakCheck ou .IntelligenceX.
- 3.1.5 Il est recommandé d'utiliser des environnements isolés (sandbox) pour l'analyse des liens et fichiers potentiellement dangereux. Utiliser les outils ci-dessous pour répondre aux questions.
 - Phishtool
 - JoeSandbox
 - Cuckoo Sandbox
 - Any.run
 - AbuseIPDB
 - VirusTotal
 - Hybrid-Analysis
- 3.1.5 a) Repérer les signaux d'alerte indiquant que le courriel reçu est frauduleux et non légitime.
- 3.1.5 b) Si on décide de répondre à ce courriel, à quelle adresse la réponse sera-t-elle envoyée ?
- 3.1.5 c) Quelle est l'adresse IP d'origine ? De quel pays provient cette adresse IP (géolocalisation) ?
- 3.1.5 d) Combien de sauts le courriel effectue-t-il avant d'arriver au destinataire ?
- 3.1.5 e) Quel type d'exploit est déclenché après l'exécution de la pièce-jointe chez la victime ?
- 3.1.5 f) Quel est le CVE associé à cet exploit ?
- 3.1.5 g) Quel logiciel malveillant est téléchargé depuis l'internet suite à l'exécution du fichier ?
- 3.1.5 h) Quelle IP et quel port sont utilisés pour la communication avec le serveur C2 ?
- 3.1.5 i) Quel est le nom de l'exécutable qu'il dépose sur le disque après son exécution ?
- 3.1.5 j) Quel groupe de ransomware est à l'origine de cette attaque ? Utiliser ID Ransomware
- 3.1.5 k) Quels indicateurs de compromission pertinents issus de cette campagne faut-il partager avec la communauté cyber ?

3.2 Attaque - Mise en oeuvre de campagnes d'hameçonnage [/3pts]

Elaborer et exécuter une attaque d'hameçonnage par courriel ciblant am.intrusion@gmail.com. Joignez-y le code source de votre attaque de clé USB piégée vue en section 2.

L'attaque doit être la plus réaliste, furtive et originale possible ! Noter vos matricules en signature !

4 Moyens de défense contre les campagnes d'hameçonnage [/20pts]

Félicitations ! Votre contribution a été extrêmement utile.

En reconnaissance de vos compétences dans ce domaine, la direction de Polytechnique Montréal a pris la décision de vous confier un mandat afin d'accompagner l'équipe TI dans l'élaboration de stratégies de défense contre les attaques par hameçonnage.

Vous avez accepté cette mission avec enthousiasme. Veuillez répondre aux questions ci-dessous.

4.1 Moyens de prévention [/6pt]

4.1.1 Quelles mesures peuvent être prises pour minimiser la collecte de numéros de téléphone et d'adresses courriels ? Justifier la réponse.

4.1.2 Pourquoi il est déconseillé de cliquer sur un lien ou d'ouvrir une pièce jointe sans l'avoir analysé dans une sandbox ? Quels risques encoure-t-on en procédant ainsi ?

4.1.3 Comment Polytechnique Montréal pourrait prévenir l'usurpation de son nom de domaine ?

4.1.4 Pourquoi il n'est pas recommandé de stocker ses mots de passe dans le navigateur ?

4.1.5 Certains auteur(e)s de cybermenaces surveillent activement les soumissions publiques sur les plateformes d'analyse en ligne comme VirusTotal, Browseling ou encore Phishtool dans le but d'adapter leurs moyens d'attaques en conséquences. Comment agir dans cette situation ?

4.1.6 Le dilemme associé aux IoCs réside dans le grand nombre de faux positifs. Dans cette situation, serait-il préférable d'incorporer tous les IoCs dans les outils de défense, même au risque de bloquer des connexions légitimes, ou bien serait-il plus judicieux de sélectionner les IoCs que l'on estime pertinents ? Justifier votre réponse.

4.1.7 Quelle(s) solution(s) technologique(s) une entreprise peut-elle utiliser pour prévenir des attaques par hameçonnage, par exemple ?

4.2 Moyens de détection [/2pts]

4.2.1 Comment peut-on déterminer si un lien a été précédemment cliqué ou visité ?

4.2.2 De manière générale, quels sont les signes et symptômes d'une infection ?

4.2.3 Quelle(s) solution(s) technologique(s) une entreprise peut-elle utiliser pour détecter des attaques par hameçonnage, par exemple ?

4.3 Moyens de réaction [/12pts]

4.3.1 Comment réagir en cas de clic accidentel sur un lien douteux ?

4.3.2 Comment rapporter un SMS ou un courriel indésirable à titre personnel ?

4.3.3 Un playbook de réponse à une attaque par hameçonnage vous est proposé ici. Expliquez-le brièvement en vos propres mots. Quelle(s) modification(s) y apporteriez-vous ?

4.3.4 Comment OpenCTI peut-il être utilisé pour détecter, analyser et répondre à une menace ?

4.3.5 Quelle(s) solution(s) technologique(s) une entreprise peut-elle utiliser pour automatiser les réponses aux attaques par hameçonnage, par exemple ?